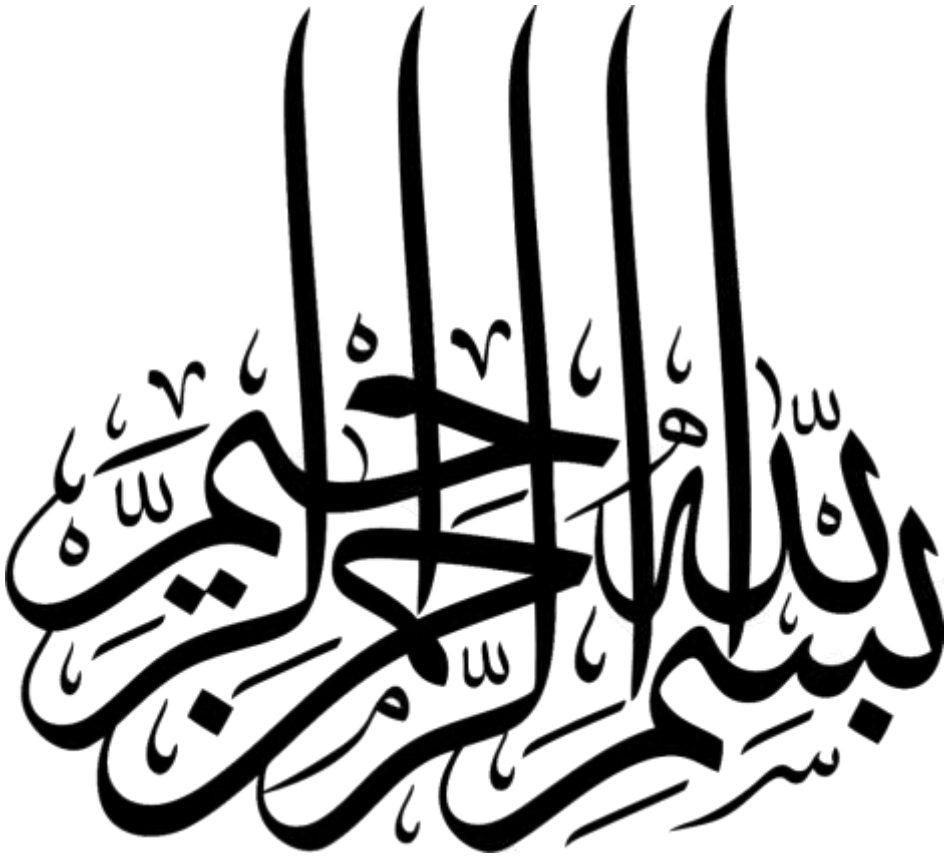

بسم الله الرحمن الرحيم

گزارش تست نفوذپذیری

سامانه automtic.fanava.com

مشخصات سند:

کارفرما	پیمانکار	تاریخ نگارش سند
گروه فناوا	دهکده امن فناورانه صبا	۱ مرداد ماه ۱۴۰۵

تهیه شده توسط	شماره مستند	طبقه بندی
مدیریت فنی و ارزیابی	TARA-PRO-1405-0501-031	محرمانه

مشخصات شرکت:

آدرس	شماره تماس
تهران – خیابان انقلاب اسلامی – خیابان استاد نجات الهی	۰۲۱-۸۸۹۳۵۹۲۰
کوچه سلمان پاک – پلاک ۱۶ واحد ۴	۰۲۱-۲۸۴۲۶۰۷۸

تمام مطالب مندرج در این سند متعلق به شرکت دهکده امن فناورانه صبا و استفاده از آن منوط به مجوز کتبی از شرکت می‌باشد.



فهرست مطالب

عنوان صفحه

مقدمه و خلاصه نتایج ۴

متدولوژی آزمون نفوذ ۵

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون ۷

محیط ارزیابی ۷

شناسایی وب‌سرور ..... **Error! Bookmark not defined.**

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه ..... **Error! Bookmark not defined.**

خلاصه مدیریتی ۸

تشریح آسیب‌پذیری‌های کشف شده ۱۲

آسیب‌پذیری بارگذاری فایل با محتوی مخرب ۱۳

آسیب‌پذیری Cross Site Scripting (XSS) - Store ..... **Error! Bookmark not defined.**

آسیب‌پذیری Reverse DoS ۱۳

آسیب‌پذیری عدم مدیریت پیام‌های خطا ۱۳

آسیب‌پذیری Server-Side Request Forgery (SSRF) ۱۳

عدم وجود سرآیندهای امنیتی HTTP ۱۳

آسیب‌پذیری نشت اطلاعات ..... **Error! Bookmark not defined.**

مقدمه و خلاصه نتایج

در دنیای امروز، که هر شرکت یا سازمانی دارایی‌های مختلف حوزه فناوری اطلاعات را در خود جای داده است، امنیت این دارایی‌ها نیز در جایگاه مهمی قرار می‌گیرد. با گسترش روزافزون تهدیدات سایبری و پیچیده‌تر شدن شیوه‌های نفوذ، تکیه بر ابزارهای دفاعی سنتی به تنهایی کافی نیست؛ از این رو، ارزیابی مستمر و شناسایی فعالانه نقاط ضعف پیش از بهره‌برداری توسط مهاجمان، به یکی از ارکان اصلی استمرار کسب‌وکار تبدیل شده است.

در اکوسیستم دیجیتالِ امروز، دارایی‌های فناوری اطلاعات نه تنها زیرساخت تداوم خدمات، بلکه قلب تپنده و حافظ سرمایه‌های استراتژیک سازمان هستند. با این حال، امنیت در فضای سایبری حالتی ایستا ندارد؛ بلکه تابعی است از تکامل مداوم تکنولوژی و هوشمندی تهدیداتی که هر روز پیچیده‌تر و هدفمندتر می‌شوند.

تکیه بر تنظیمات پیش‌فرض یا ابزارهای امنیتی معمول، اگرچه لایه‌ای از حفاظت را ایجاد می‌کند، اما به معنای مصونیت مطلق نیست؛ چرا که نفوذگران همواره به دنبال شناسایی شکاف‌هایی هستند که از دید سیستم‌های نظارتی دور مانده یا به دلیل خطاهای پیکربندی انسانی نادیده گرفته شده‌اند.

ارزیابی امنیتی و تست نفوذ که در این گزارش ارائه شده است، فراتر از یک بررسی سطحی، تلاشی است برای مشاهده‌ی سازمان از دریچه‌ی نگاه مهاجم. هدف ما در این ارزیابی، شناسایی نقاط کور و کشف مسیرهایی است که می‌تواند منجر به دسترسی‌های غیرمجاز یا نشت اطلاعات حساس گردد.

این گزارش حاصل تست نفوذ انجام شده بر روی **وب سایت automtic.fanava.com** است که با هدف ارزیابی جامع امنیت دارایی‌های دیجیتال **گروه فناوا** تهیه شده است. هدف از این ارزیابی، شناسایی آسیب‌پذیری‌های امنیتی، تحلیل پیامدهای احتمالی و ارائه راهکارهای عملیاتی جهت کاهش ریسک و ارتقای سطح بلوغ امنیتی زیرساخت‌ها بوده است.

متدولوژی آزمون نفوذ

به منظور حصول اطمینان از دقت، جامعیت و قابلیت بازتولید یافته‌ها، فرآیند ارزیابی امنیتی در این پروژه بر اساس استاندارد جهانی WSTG (Web Security Testing Guide) تدوین‌شده توسط بنیاد امنیتی OWASP در ترکیب با تجربه عملی متخصصان شرکت صورت گرفته است. این چارچوب مرجع، به عنوان استاندارد صنعتی برای تست نفوذ برنامه‌های کاربردی تحت وب، لایه‌های مختلف امنیتی از پیکربندی سرور و مدیریت نشست‌ها گرفته تا کنترل‌های احراز هویت و دسترسی را تحت پوشش قرار می‌دهد.

در اجرای این متدولوژی، مراحل زیر به صورت گام‌به‌گام پیاده‌سازی شده است:

- **فاز شناسایی و جمع‌آوری اطلاعات:** تحلیل ساختار برنامه، شناسایی تکنولوژی‌های مورد استفاده، نقشه‌برداری از سطوح حمله و کشف فایل‌ها و دایرکتوری‌های حساس.
- **فاز تحلیل پیکربندی و کنترل‌های امنیتی:** بررسی تنظیمات امنیتی وب‌سرور، نحوه مدیریت نشست‌ها، مکانیزم‌های احراز هویت و مجوزدهی، و تحلیل نحوه برخورد سیستم با داده‌های ورودی کاربر.
- **فاز شناسایی آسیب‌پذیری‌ها:** اجرای تست‌های هدفمند برای کشف نقاط ضعف در لایه‌های مختلف از جمله تزریق کد، XSS، کنترل‌های دسترسی ناامن و سایر ریسک‌های شناخته شده در استاندارد WSTG.
- **فاز بهره‌برداری و تأیید آسیب‌پذیری شناسایی شده:** تلاش کنترل‌شده برای بهره‌برداری از آسیب‌پذیری‌های شناسایی شده به منظور اثبات صحت آن‌ها و درک میزان اثرگذاری هر ریسک بر روی داده‌ها و عملکرد کلی سیستم.

پس از شناسایی و تأیید آسیب‌پذیری‌ها، جهت تحلیل دقیق و استاندارد سطح ریسک هر یافته، از سیستم امتیازدهی CVSS (Common Vulnerability Scoring System) استفاده شده است. این مدل با در نظر گرفتن فاکتورهای فنی نظیر بردار حمله، میزان پیچیدگی بهره‌برداری و تأثیر بر محرمانگی، یکپارچگی و دسترس‌پذیری اطلاعات، عددی را بین ۰ تا ۱۰ به هر آسیب‌پذیری اختصاص می‌دهد.

بهره‌گیری از CVSS به سازمان کمک می‌کند تا با زبانی مشترک و تخصصی، اهمیت یافته‌ها را درک کرده و فرآیند اصلاح را بر اساس اولویت‌بندی دقیق و منطقی مدیریت نماید. بدین ترتیب، آسیب‌پذیری‌هایی با امتیاز بالاتر، به عنوان اولویت‌های فوری برای تیم فنی جهت کاهش سطح حمله و ارتقای تاب‌آوری سیستم تعیین شده‌اند.

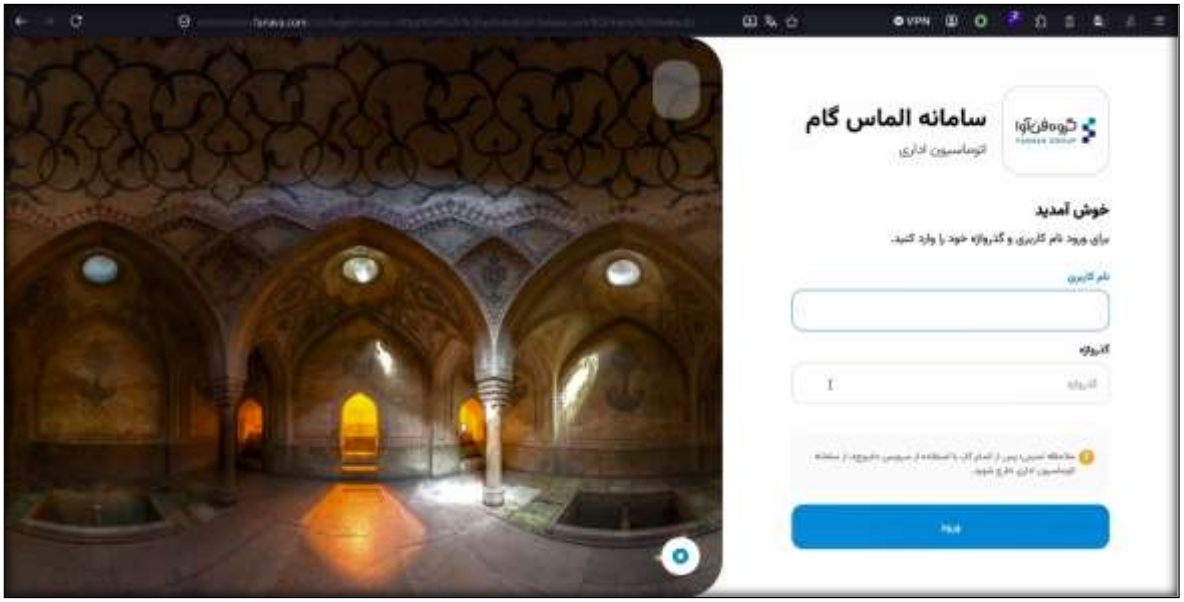
این رویکرد ساختاریافته به تیم ارزیاب اجازه می‌دهد تا فراتر از ابزارهای خودکار، با نگاهی تحلیلی به بررسی پیچیدگی‌های منطقی برنامه بپردازد و اطمینان حاصل کند که تمامی جنبه‌های حیاتی امنیتِ وب‌سایت در برابر تهدیدات پیشرفته مورد سنجش قرار گرفته‌اند.

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون

محیط ارزیابی

در این بخش، نمایی از وب‌سایت هدف جهت مستندسازیِ وضعیت سیستم در زمان شروع ارزیابی ارائه شده است. این تصویر به عنوان مرجعی برای تایید دامنه فعالیت و شناسایی بصری رابط کاربریِ سیستمِ تحت تست می‌باشد.

سامانه هدف با آدرس https://automtic.fanava.com در حال سرویس‌دهی است که صفحه نخست آن در تصویر زیر نمایش داده شده است:



لازم به ذکر است که نام کاربری pentest به منظور ارزیابی، در اختیار تیم تست نفوذ قرار گرفته است.

نکته: لازم به است این نام کاربری می‌بایست پس از ارسال گزارش به صورت کامل (حساب کاربری به همراه تمام فعالیت‌های آن) از سامانه حذف شود.

خلاصه مدیریتی

ارزیابی امنیتی انجام‌شده بر روی سامانه automtic.fanava.com نشان می‌دهد که علی‌رغم لایه‌های حفاظتی موجود، چندین شکاف امنیتی با سطوح ریسک متفاوت در معماری و پیاده‌سازی سامانه وجود دارد. شناسایی و بهره‌برداری از این موارد می‌تواند منجر به بروز مخاطرات جدی از قبیل دسترسی غیرمجاز به اطلاعات کاربران، اختلال در دسترس‌پذیری سرویس و در نهایت آسیب به اعتبار سازمانی گردد.

تحلیل وضعیت موجود

یافته‌های این گزارش بر اساس سیستم امتیازدهی CVSS دسته‌بندی شده‌اند تا مدیران و تیم فنی بتوانند فرآیند مقاوم‌سازی را با اولویت‌بندی صحیح آغاز کنند:

- **ریسک‌های سطح زیاد:** این موارد شامل آسیب‌پذیری‌هایی است که اجازه دور زدن کنترل‌های امنیتی اصلی (مانند کپچا) یا اجرای حملات مخرب (مانند بارگذاری فایل‌های غیرمجاز و حملات DoS) را به مهاجم می‌دهد. رفع این موارد به دلیل پتانسیل بالای سوءاستفاده، اولویت نخست سازمان محسوب می‌شود.
- **ریسک‌های سطح متوسط:** این یافته‌ها به شکاف‌هایی در پیکربندی، مدیریت نشست‌ها و اعتبارسنجی ورودی‌ها اشاره دارد. اگرچه این موارد ممکن است به تنهایی منجر به نفوذ کامل نشوند، اما می‌توانند در زنجیره‌ای از حملات، راه را برای نفوذگر هموار سازند.
- **ریسک‌های سطح کم:** مربوط به عدم استفاده از برخی استانداردهای امنیتی HTTP است که اگرچه خطر مستقیم ایجاد نمی‌کنند، اما «لایه دفاعی» سامانه را ضعیف کرده و شناساییِ هدف را برای مهاجم آسان‌تر می‌کنند.

جمع بندی:

بر اساس نتایج ارزیابی امنیتی سامانه، مجموعه‌ای از آسیب‌پذیری‌های با شدت زیاد، متوسط و کم شناسایی شده که نشان‌دهنده وجود ضعف‌هایی در لایه‌های ورودی، منطق پردازش، مدیریت دسترسی و پیکربندی امنیتی سامانه است. بخش قابل توجهی از یافته‌ها در سطح زیاد قرار دارند؛ از جمله SQL Injection، Stored XSS، بارگذاری فایل مخرب، DoS و سوءاستفاده از محدودیت توابع که همگی می‌توانند زمینه‌ساز نفوذ، اختلال در سرویس و دسترسی غیرمجاز به اطلاعات حساس شوند.

همچنین وجود آسیب‌پذیری‌های سطح متوسط مانند اعتبارسنجی نامناسب ورودی‌ها، ضعف در سیاست گذرواژه، دست‌کاری IP کلاینت، مدیریت نامناسب پیام‌های خطا و بارگذاری فایل با حجم بالا نشان می‌دهد که کنترل‌های امنیتی سامانه در برابر سوءاستفاده‌های هدفمند و زنجیره‌ای به اندازه کافی مقاوم نیستند.

در مجموع، وضعیت امنیتی فعلی سامانه در سطح پرریسک و نیازمند اقدام فوری ارزیابی می‌شود؛ زیرا مهاجم می‌تواند با بهره‌برداری از آسیب‌پذیری‌های بحرانی، منجر به نفوذ به زیرساخت، اجرای کد یا اسکریپت

مخرب، سرقت نشست کاربران، افشای اطلاعات و توقف سرویس‌دهی شود. بنابراین توصیه می‌شود اقدامات اصلاحی و راهکارهای ارائه شده در این گزارش مد نظر قرار گرفته و به سرعت اصلاحات لازم صورت پذیرد.

لازم به ذکر است که آسیب‌پذیری‌های سطح ریسک متوسط و کم نباید نادیده گرفته شده و با توجه به تجمیع برخی از آن‌ها، امکان سوء استفاده از این سطح آسیب‌پذیری‌ها در صورت عدم رفع، وجود خواهد داشت.

خلاصه یافته‌های ارزیابی



در جدول زیر، تمامی آسیب‌پذیری‌های شناسایی‌شده در طول ارزیابی امنیتی، بر اساس شدت ریسک و طبق CVSS دسته‌بندی شده‌اند. این طبقه‌بندی به سازمان کمک می‌کند تا با نگاهی کلان، اولویت‌های اصلی امن‌سازی خود را شناسایی و منابع فنی را به بهینه‌ترین شکل برای رفع آن‌ها تخصیص دهد.

درجه اهمیت	توضیح آسیب‌پذیری
زیاد	آسیب‌پذیری SQL Injection
زیاد	آسیب‌پذیری Function Limit Use
زیاد	آسیب‌پذیری Cross Site Scripting (XSS) - Stored
زیاد	آسیب‌پذیری بارگذاری فایل با محتوای مخرب
زیاد	آسیب‌پذیری DoS
متوسط	آسیب‌پذیری عدم مدیریت پیام‌های خطا
متوسط	آسیب‌پذیری بارگذاری فایل با حجم بالا
متوسط	آسیب‌پذیری اعتبارسنجی نامناسب ورودی‌ها
متوسط	آسیب‌پذیری Client IP Manipulation
متوسط	آسیب‌پذیری Weak Password Policy
کم	عدم وجود سرآیندهای امنیتی HTTP

توصیه

شایان ذکر است آسیب‌پذیری‌های گزارش‌شده در بخش‌های آتی، به عنوان نمونه‌های شاخص از وضعیت امنیتی سامانه ارائه شده‌اند. از این رو، اکیداً توصیه می‌شود تیم فنی سازمان، راهکارهای اصلاحی ارائه‌شده را نه تنها برای نمونه‌های تست‌شده، بلکه به صورت جامع در تمامی بخش‌ها و ماژول‌های مشابه در کل سامانه اعمال نمایند تا از بروز شکاف‌های امنیتی مشابه در سایر نقاط سیستم جلوگیری شود.

همچنین با توجه به ماهیت تجاری سامانه مورد ارزیابی و محدودیت‌های عملیاتی در اعمال تغییرات ساختاری، اکیداً توصیه می‌شود فرآیند به‌روزرسانی و وصله‌امنیتی در بازه‌های زمانی کوتاه‌مدت و به صورت مستمر اجرایی گردد. همچنین، جهت پوشش شکاف‌های امنیتی موجود و کاهش ریسک ناشی از آسیب‌پذیری‌های شناسایی‌شده، استقرار یک **دیواره آتش اپلیکیشن‌های وب (WAF)** به عنوان یک لایه دفاعی مکمل، نقشی حیاتی در خنثی‌سازی حملات و ارتقای سطح پایداری سامانه ایفا خواهد کرد.

تشریح آسیب‌پذیری‌های کشف شده

در ادامه، برای آسیب‌پذیری‌های کشف‌شده در سامانه، توضیحات تکمیلی مرتبط ارائه شده است:

آسیب‌پذیری SQL Injection

یکی از آسیب‌پذیری‌هایی که در دسته بندی اعتبارسنجی ورودی‌ها یا Input Validation قرار می‌گیرد، آسیب‌پذیری SQL Injection است. این آسیب‌پذیری هنگامی رخ می‌دهد که برنامه نویس، هنگام دریافت ورودی از کاربر، آن‌ها را به درستی مدیریت نکرده و این ورودی‌ها را مستقیماً به دیتابیس ارسال می‌کند.

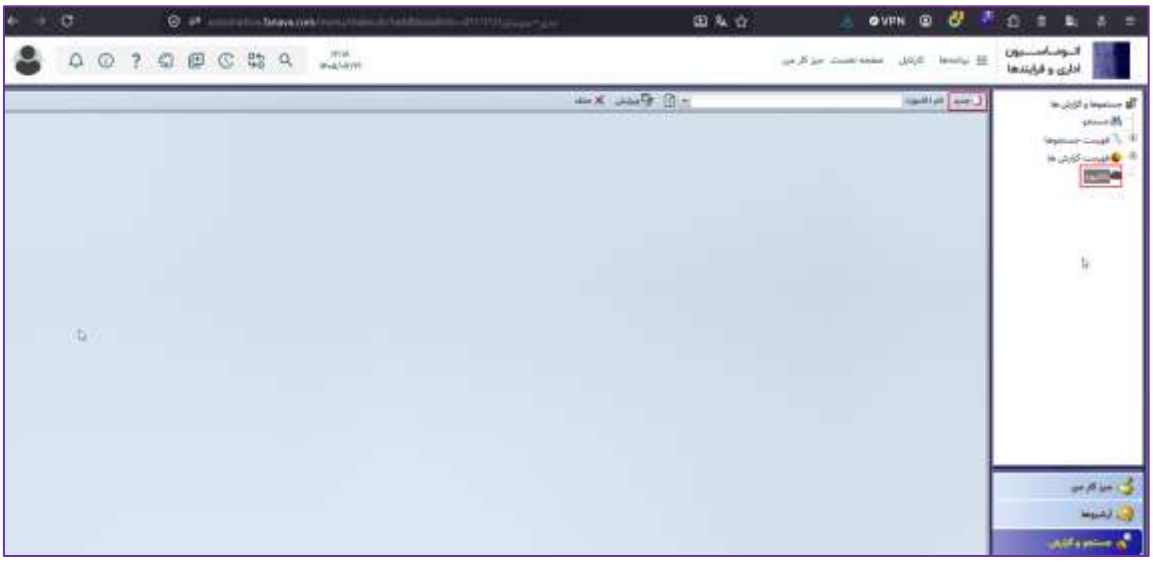
دسته بندی‌های مختلفی از آسیب‌پذیری SQL Injection با توجه به نوع کدنویسی وجود دارد ولی اغلب دو دسته بندی کلی Inband و Blind برای این آسیب‌پذیری تعریف می‌شود که در نوع Inband پس از ارسال کوئری مورد نظر مهاجم، پاسخ ارسالی از سمت دیتابیس برای وی قابل مشاهده بوده ولی در نوع Blind امکان مشاهده پاسخ دیتابیس وجود ندارد و مهاجم باید با عبارات True/False، صحت کوئری ارسال شده را تشخیص دهد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش اسناد برنامه، قسمتی برای جستجو و گزارش وجود دارد. در قسمت داشبورد امکان ایجاد یک داشبورد جدید و وارد کردن کوئری sql وجود دارد. مهاجم در این بخش کوئری مد نظر خود را وارد می‌کند. در صورتی که کوئری درست باشد در خروجی داشبورد خطا نمایش داده می‌شود و در صورتی که کوئری اشتباه باشد تنها یک صفحه خالی نمایش داده می‌شود. مهاجم با قرار دادن کوئری‌های مختلف و بررسی نمایش یا عدم نمایش خطا امکان استخراج اطلاعات از دیتابیس سامانه را دارد.

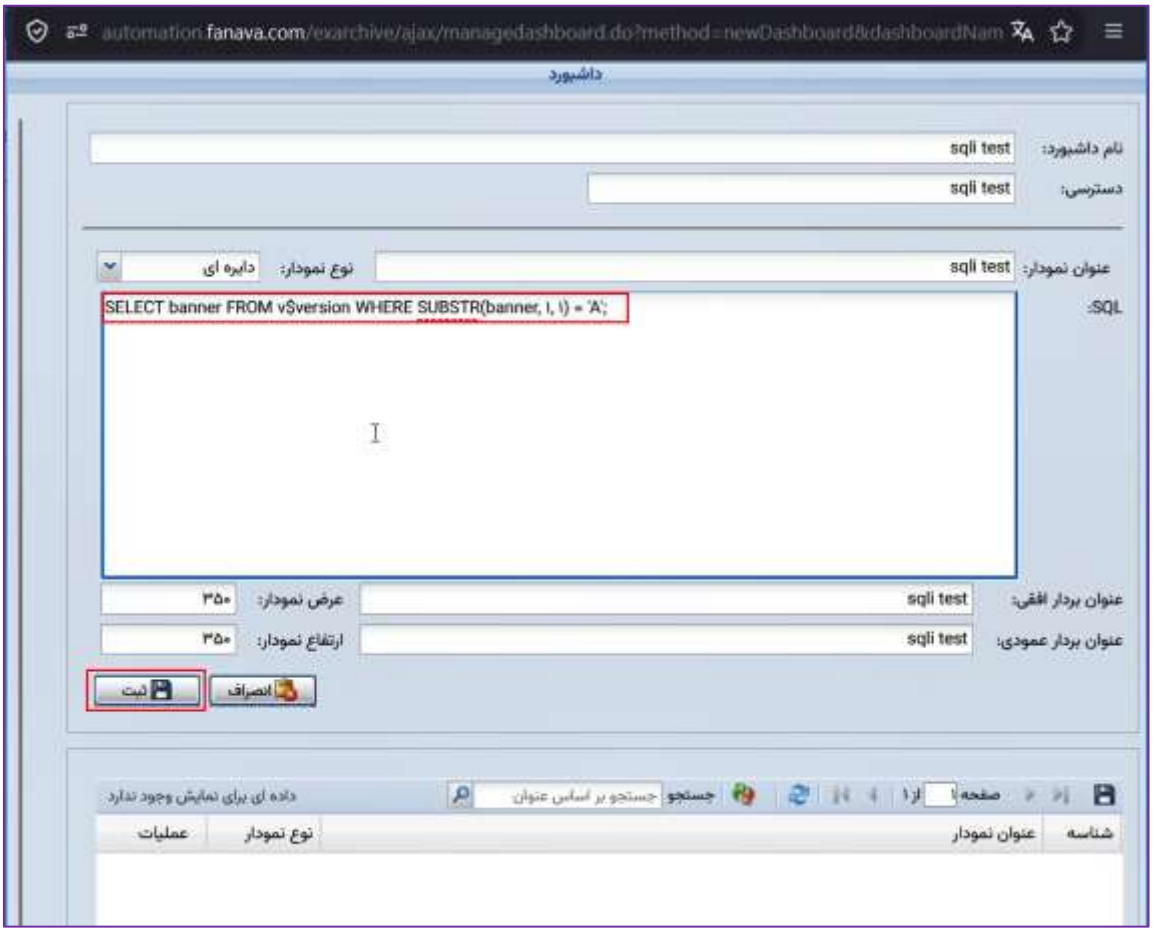
تصاویر زیر بخش جستجو و گزارش از بخش اسناد را نشان می‌دهد. کاربر بر روی گزینه داشبورد کلیک می‌کند و اقدام به ایجاد یک داشبورد جدید می‌کند:





تصویر زیر بخش ایجاد داشبورد جدید را نشان می‌دهد. همان‌طور که در این تصویر قابل مشاهده است مهاجم کوئری زیر را وارد می‌کند تا بررسی کند حرف اول از مقدار Banner دیتابیس با A برابر است یا خیر. سپس بر روی گزینه ثبت کلیک می‌کند.

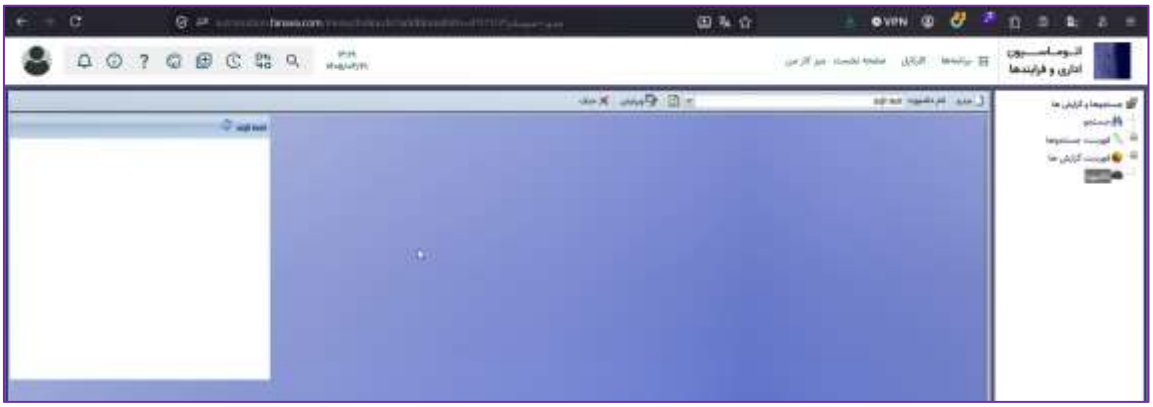
```
SELECT banner FROM v$version WHERE SUBSTR(banner, 1, 1) = 'A'
```



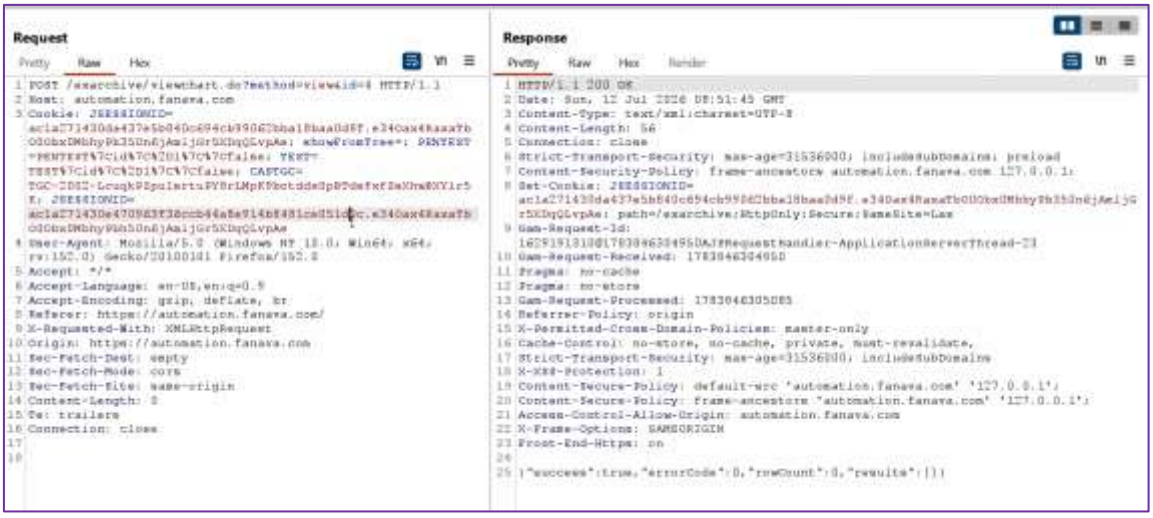
درخواست ثبت و ویرایش داشبورد در تصویر زیر نمایش داده شده است:



همان‌طور که در تصویر زیر قابل مشاهده است یک داشبورد جدید ایجاد شده که تنها یک صفحه خالی را نمایش می‌دهد:

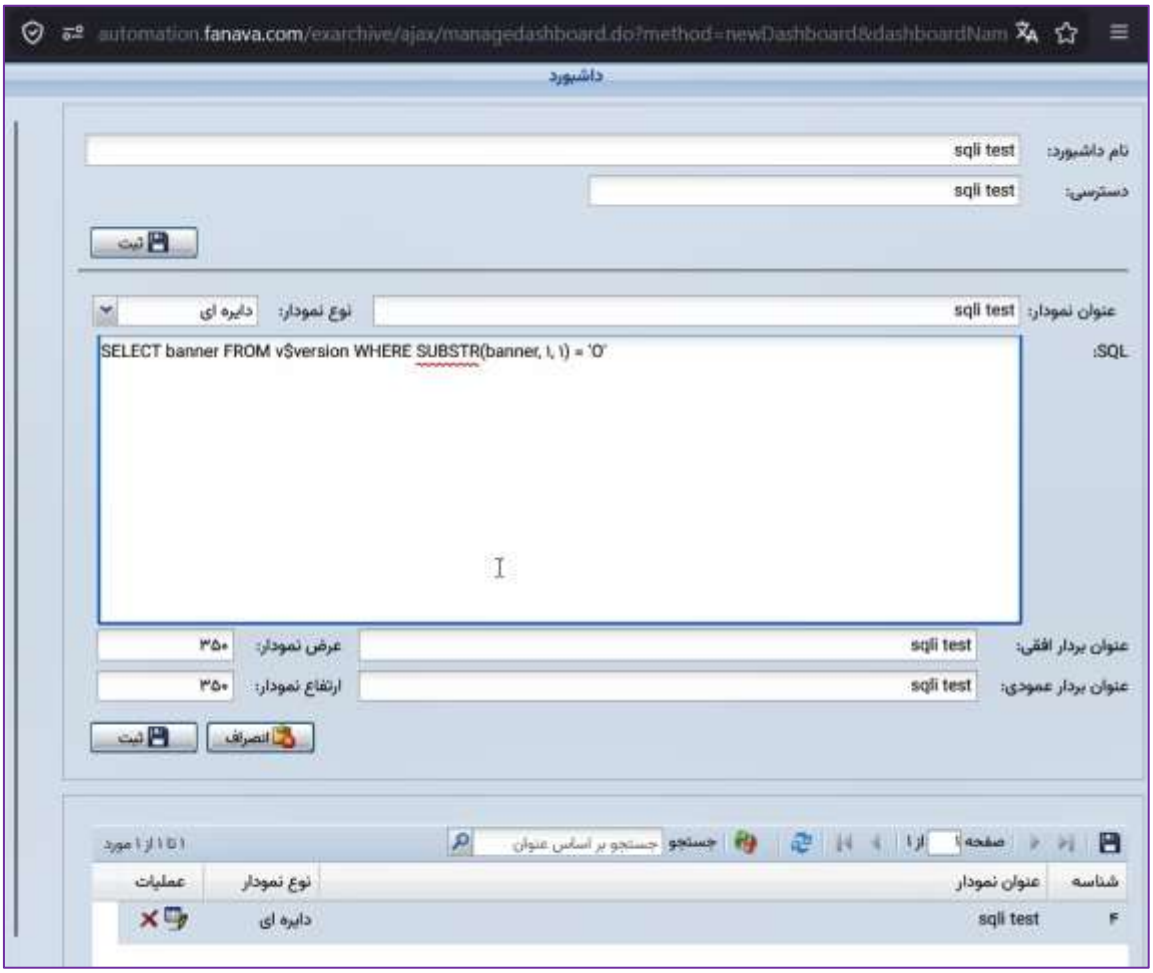


درخواست مشاهده داشبورد به شرح زیر است:

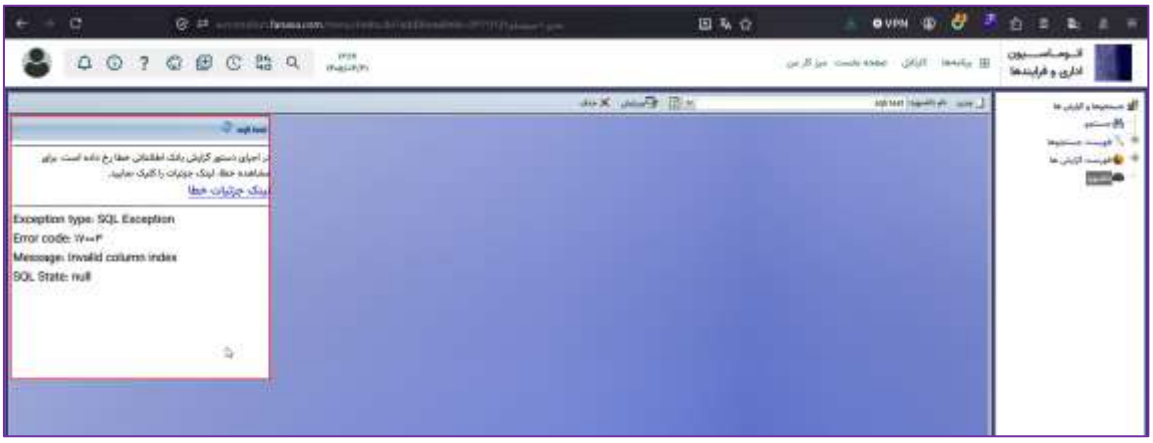


در تصویر زیر مهاجم داشبورد را ویرایش می‌کند و به جای حرف A مقدار O را قرار می‌دهد و داشبورد را ثبت می‌کند:

```
SELECT banner FROM v$version WHERE SUBSTR(banner, 1, 1) = 'O'
```

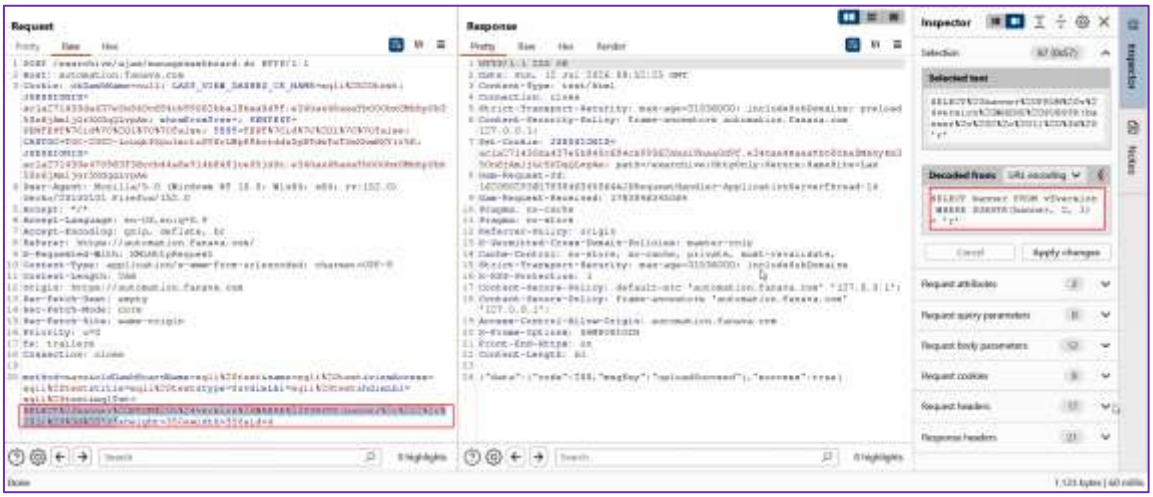


همان‌طور که در تصویر زیر قابل مشاهده است در خروجی این داشبورد یک خطای SQL نمایش داده شده است که نشان دهنده درستی کوئری مهاجم می‌باشد. (یعنی حرف اول Banner دیتابیس با O برابر است).

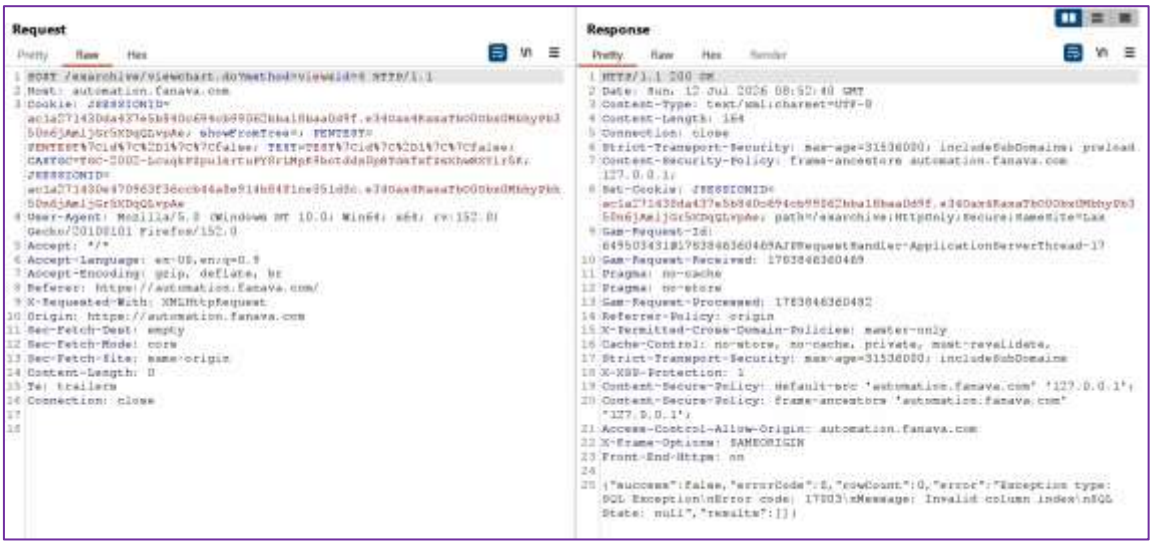


در ادامه مهاجم برای پیدا کردن حرف دوم Banner دیتابیس را از طریق درخواست ثبت داشبورد اقدام می‌کند. در این کوئری مقدار r قرار داده شده است:

```
SELECT banner FROM v$version WHERE SUBSTR(banner, 2, 1) = 'r'
```



تصویر زیر درخواست مشاهده داشبورد را نشان می‌دهد. همان‌طور که قابل مشاهده می‌باشد در خروجی آن خطای SQL وجود دارد که نشان دهنده درستی کوئری ارسال شده به سمت سامانه می‌باشد. (یعنی حرف دوم Banner دیتابیس با مقدار r برابر است).



مهاجم به همین رویه و با قرار دادن مقادیر مختلف و بررسی خروجی آن می‌تواند اطلاعات دیتابیس را استراج کند. لازم به ذکر است که این فرایند بسیار زمان بر بوده و در ادامه ۲ مورد از اطلاعات به دست آمده نمایش داده می‌شود:

Database banner info	Oracle
Database username	GAM_ARCHIVE

راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

استفاده از کوئری‌های آماده‌سازی شده (Prepared Statements): با استفاده از این روش، به جای این‌که مستقیماً مقادیر ورودی را در SQL قرار دهید، از پارامترهای جایگزین (Placeholders) استفاده می‌کنید.

استفاده از PDO به جای pg_query: PDO به طور خودکار از کوئری‌های آماده‌سازی شده پشتیبانی می‌کند و به شما امکان می‌دهد ورودی‌های کاربر را به درستی ایمن‌سازی کنید.

پاکسازی و اعتبارسنجی داده‌های ورودی: علاوه بر استفاده از کوئری‌های آماده‌سازی شده، بهتر است داده‌های ورودی پاکسازی و اعتبارسنجی شود. به عنوان مثال اطمینان حاصل کنید که ورودی‌هایی که قرار است به عنوان اعداد استفاده شوند، به طور کامل اعداد هستند. همچنین می‌توان از توابع PHP مانند filter_var برای فیلتر کردن ورودی‌ها استفاده شود.

استفاده از ORM (Object-Relational Mapping): استفاده از ORMهایی مانند Doctrine یا Eloquent در PHP می‌تواند به کاهش استفاده مستقیم از SQL کمک کند و منجر به امنیت بیشتری در برابر SQL Injection شود.

لازم به ذکر است که موارد مذکور در این بخش، به منظور پیشگیری از بروز آسیب‌پذیری SQL Injection به صورت کلی می‌باشد. در صورتی که این قابلیت برای کاربران مورد نیاز نیست، پیشنهاد می‌شود که به صورت کلی غیرفعال شده یا صرفاً دسترسی به آن برای کاربران سطح مدیر با دسترسی محدود امکان پذیر باشد.

آسیب‌پذیری Function Limit Use

آسیب‌پذیری‌های مرتبط با جریان کار در منطق کسب و کار، هر نوعی از آسیب‌پذیری را که مهاجم امکان سوءاستفاده از برنامه یا سیستم را داشته باشد به نحوی که بتواند فرایند جریان کار فعالیت‌ها را دور بزند، (حذف یا جابجا و یا اضافه کند)، شامل می‌شود.

شواهد اثبات آسیب پذیری

تصویر زیر صفحه ویرایش و اصلاح نامه ارجاع شده را نمایش می‌دهد. با کلیک بر روی الصاق فایل امکان بارگذاری فایل وجود دارد:



در مرحله بعد کاربر فایل مد نظر خود را انتخاب می‌کند و بر روی گزینه شروع بارگذاری کلیک می‌کند:



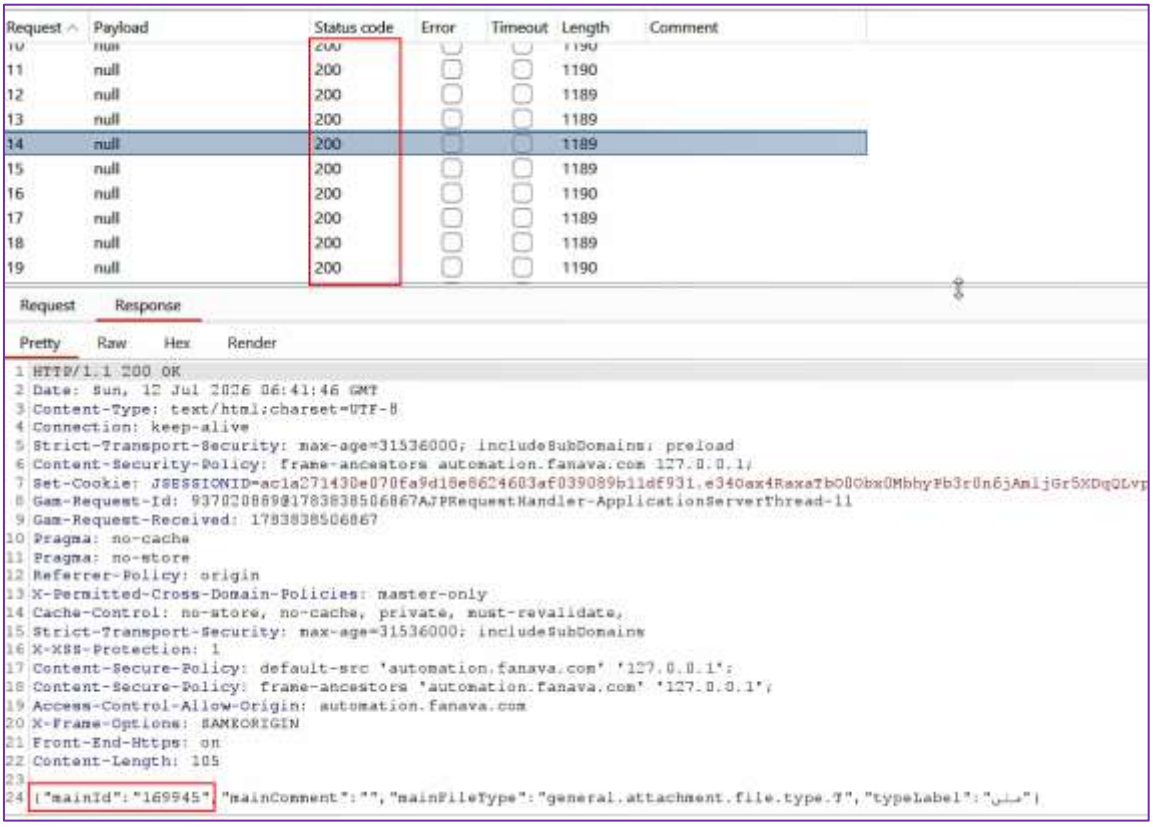
تصویر زیر درخواست بارگذاری فایل را نشان می‌دهد:

Request

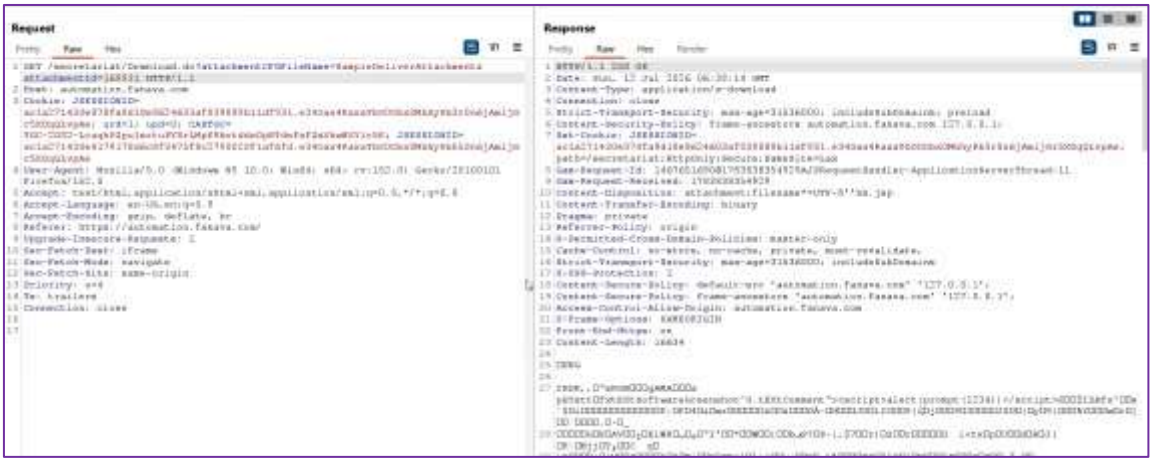
Pre | Raw | Hex

```
1  POST /secretariat/Upload.do?method=ajaxUpload HTTP/1.1
2  Host: automation.fanava.com
3  Cookie: JSESSIONID=
   ac1a271430e070fa9d18e8624603af039089b11df931.e340ax4RaxaTbO0Obx0Mbhy
   Pb3r0n6jAmljGr5XDqQLvpAe; urd=1; upd=0; CASTGC=
   TGC-2002-LcuqkPZpu1srtuPY8rLMpK9botddx0pBTdsfxfZsXhwBXYlr5K;
   JSESSIONID=
   ac1a271430e4179178d6c8f3475f8c2790020f1af6fd.e340ax4RaxaTbO0Obx0Mbhy
   Pbh50n6jAmljGr5XDqQLvpAe
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0)
   Gecko/20100101 Firefox/152.0
5  Accept: text/html, */*; q=0.01
6  Accept-Language: en-US,en;q=0.9
7  Accept-Encoding: gzip, deflate, br
8  Referer: https://automation.fanava.com/
9  X-Requested-With: XMLHttpRequest
10 Content-Type: multipart/form-data;
   boundary=----geckoformboundaryd6f25cf08f1e8924228f6941c27dcac
11 Content-Length: 18051
12 Origin: https://automation.fanava.com
13 Sec-Fetch-Dest: empty
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Site: same-origin
16 Priority: u=0
17 Te: trailers
18 Connection: close
19
20 ------geckoformboundaryd6f25cf08f1e8924228f6941c27dcac
21 Content-Disposition: form-data; name="theFile"; filename="bb.png"
22 Content-Type: image/png
23
24 □PNG
25
26 IHDR,,□"sRGB□□□gAMA□□□a
```

مهاجم این درخواست را چندین بار به صورت متوالی به سمت سامانه ارسال می‌کند. همان‌طور که در تصویر زیر قابل مشاهده است تمامی درخواست‌ها با موفقیت به سمت سامانه ارسال شده و برای هر کدام از این فایل‌ها یک شماره آی‌دی اختصاص داده شده است:



درخواست مشاهده یکی از این فایل‌ها به شرح زیر است:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا بر روی درخواست‌های ارسالی کاربر محدودیت اعمال گردد تا امکان ارسال درخواست به صورت بی‌نهایت را به سمت سامانه نداشته باشد.

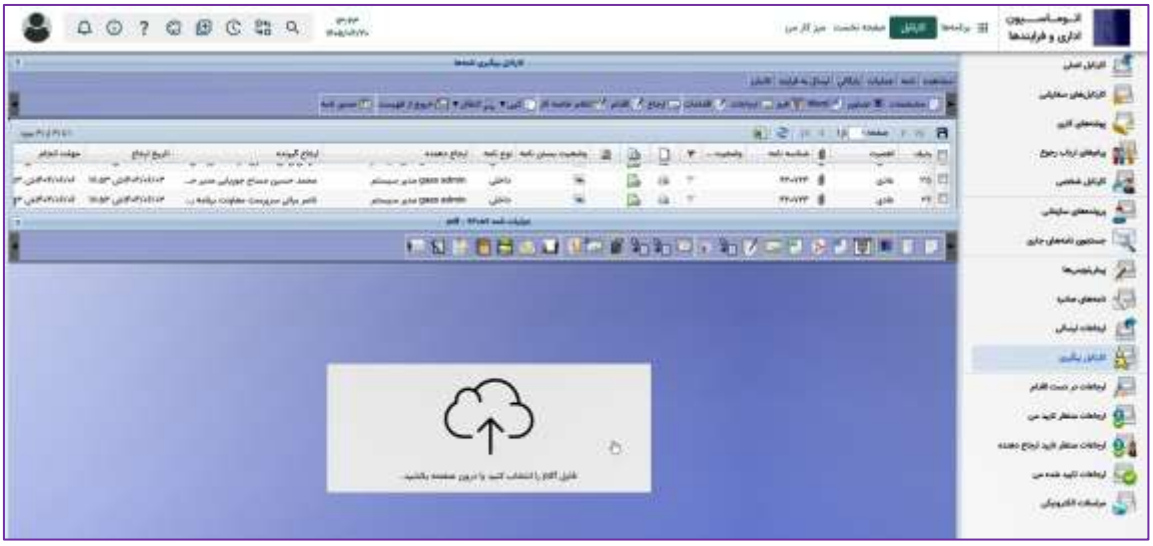
آسیب‌پذیری Cross Site Scripting (XSS) Stored

در صورتی که سامانه در فیلدهای ورودی اطلاعات خود، مانند بخش جستجوی سامانه، اعتبارسنجی مناسبی بر روی داده‌های ورودی انجام ندهد، امکان بروز این آسیب‌پذیری برای کاربر وجود دارد. اگر یک سامانه دارای این آسیب‌پذیری باشد و مهاجم بتواند پیلود مخرب خود را در ورودی‌ها وارد کند، کاربر به محض متصل شدن به صفحه آسیب‌پذیر، کد مخرب مورد نظر مهاجم را از طریق مرورگر خود اجرا می‌کند و اطلاعات حساس قربانی از این طریق برای مهاجم ارسال می‌شود. در نوع Stored، کد جاوا اسکریپت مخرب روی دیتابیس وب‌سایت آسیب‌پذیر ذخیره می‌شود و هر بار صفحه آسیب‌پذیر لود شود، پیلود مخرب مهاجم اجرا می‌شود.

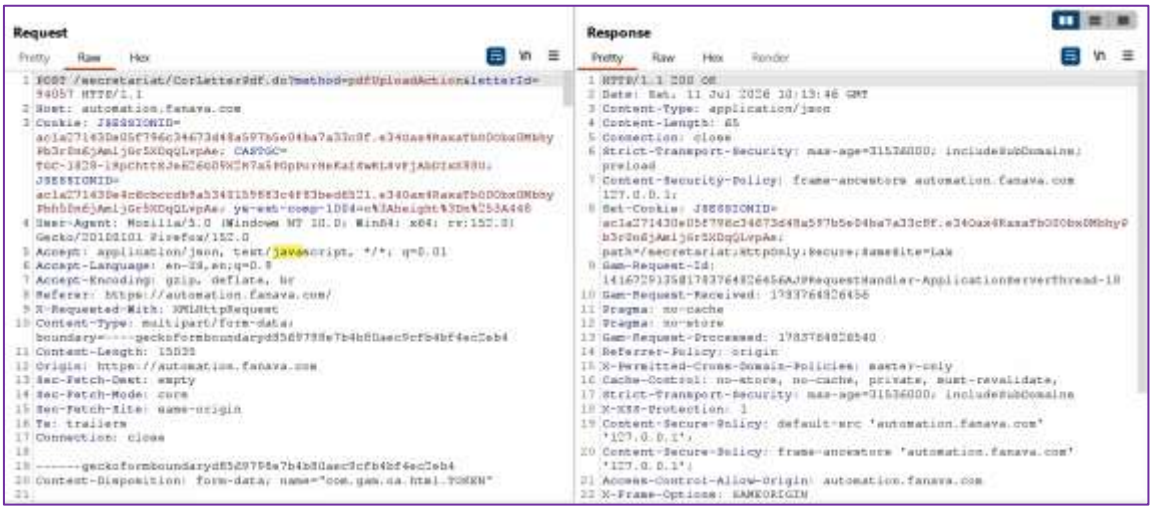
شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه در بخش کارتابل پیگیری نامه‌های وارده، امکان بارگذاری فایل PDF وجود دارد. مهاجم می‌تواند فایل PDF حاوی پیلود XSS را بارگذاری کند. با کلیک بر روی نامه وارده، فایل PDF مهاجم نمایش داده می‌شود و پیلود XSS در صفحه اجرا می‌شود.

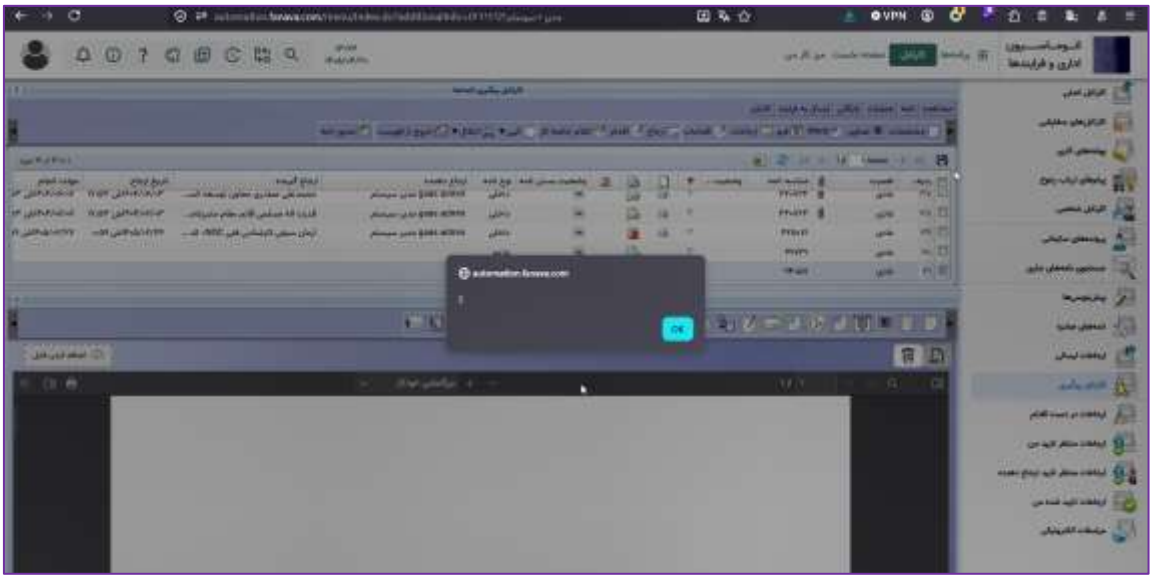
تصویر زیر بخش کارتابل پیگیری را نشان می‌دهد. مهاجم بر روی یکی از نامه‌های وارده کلیک می‌کند. همان‌طور که در تصویر زیر قابل مشاهده است امکان بارگذاری فایل PDF در این بخش وجود دارد:



تصاویر زیر درخواست بارگذاری فایل را نشان می‌دهد. همان‌طور که در تصویر دوم قابل مشاهده است در محتوای فایل PDF پیلود مخرب XSS وجود دارد:



تصویر زیر اجرای پیلود XSS در صفحه کاربر را نشان می‌دهد:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- Sanitization بر روی ورودی‌های کاربر اعمال گردد.
- برای ورودی‌های کاربر در سمت سرویس‌دهنده از لیست حروف مجاز و غیرمجاز استفاده نمود.
- استفاده از Html.Encode در سازوکار پیاده‌سازی صفحات سمت مشتری و کد سمت سرویس دهنده

استفاده از کتابخانه‌های کدگذاری امن جهت HTML Entity Encoding مانند Microsoft Anti-Cross Site Scripting Library برای .NET paltforms.

استفاده از OWASP Java Encoder Project کتابخانه کدگذاری امن با عملکرد بالا را برای زبان JAVA فراهم می‌کند.

استفاده از Escape Syntax برای قسمت‌هایی از HTML Document که امکان ورود داده‌های غیرمجاز در آنها موجود می‌باشد.

تعدادی از قوانین جلوگیری از حمله XSS:

- ورودی‌های نامتعارف / غیرمجاز نباید در هیچ یک از ورودی‌های سمت کاربر پذیرفته شوند مگر در جاهایی که مجاز باشد.

به طور مستقیم در script:

```
<script>...NEVER PUT UNTRUSTED DATA HERE...</script>
```

داخل HTML Comments:

```
<!--...NEVER PUT UNTRUSTED DATA HERE...-->
```

داخل نام مشخصه:

```
<div ...NEVER PUT UNTRUSTED DATA HERE...=test />
```

داخل Tag:

```
<NEVER PUT UNTRUSTED DATA HERE... href="/test" />
```

داخل کدهای CSS:

```
<style>
...NEVER PUT UNTRUSTED DATA HERE...
</style>
```

- Escape، قبل از ورود داده‌های غیرمجاز در محتوا HTML Element

```
<body>
...ESCAPE UNTRUSTED DATA BEFORE PUTTING HERE...
</body>

<div>
...ESCAPE UNTRUSTED DATA BEFORE PUTTING HERE...
</div>
```

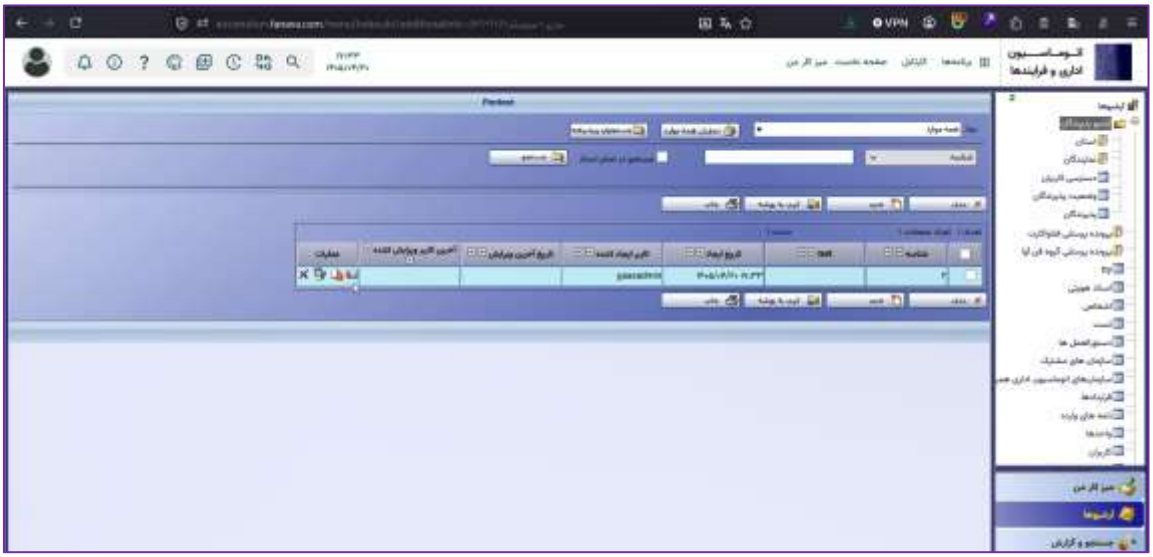
آسیب‌پذیری بارگذاری فایل با محتوی مخرب

مهاجم می‌تواند با بارگذاری فایل مخرب در سامانه منجر به آلوده شدن سرور و یا در شرایطی خطرناک‌تر ایجاد یک Backdoor در سمت سرور شود.

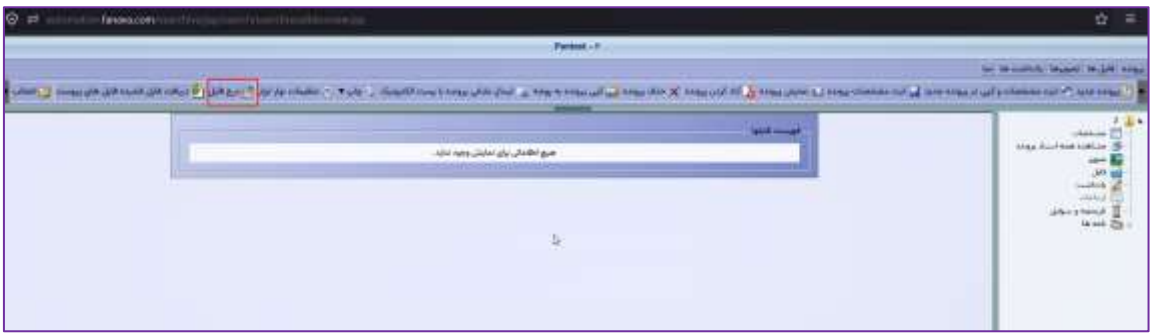
شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش آرشیوها امکان بارگذاری فایل وجود دارد. در این بخش هیچگونه کنترلی بر روی محتوا و پسوند فایل ارسالی به سمت سامانه وجود ندارد و مهاجم می‌تواند فایل با محتوای مخرب به سمت سامانه ارسال کند.

تصویر زیر بخش آرشیوهای سامانه را نشان می‌دهد. کاربر بر روی گزینه ویرایش یک آرشیو کلیک می‌کند:



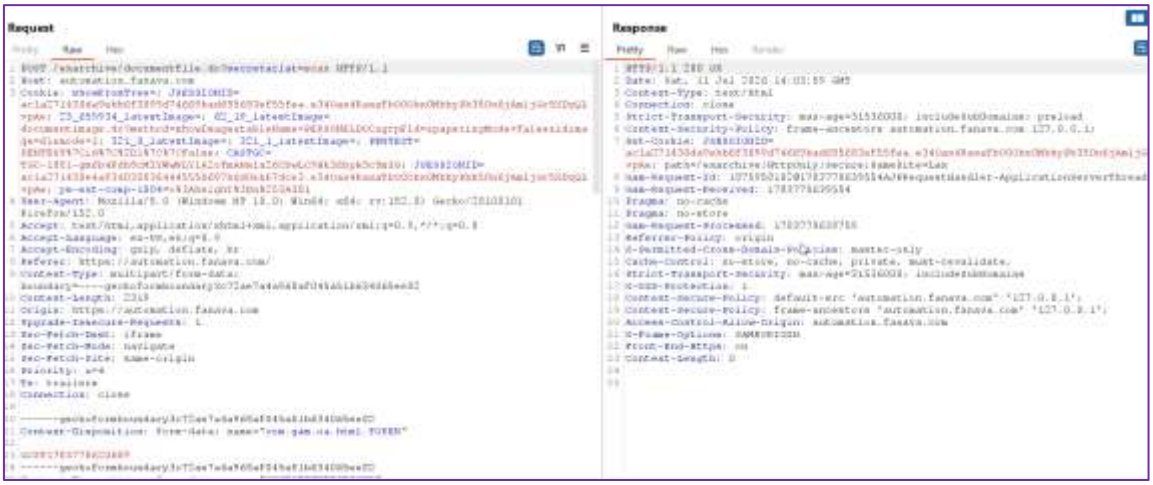
تصویر زیر بخش ویرایش آرشیو را نشان می‌دهد. در این بخش کاربر برای بارگذاری فایل بر روی گزینه درج فایل کلیک می‌کند:

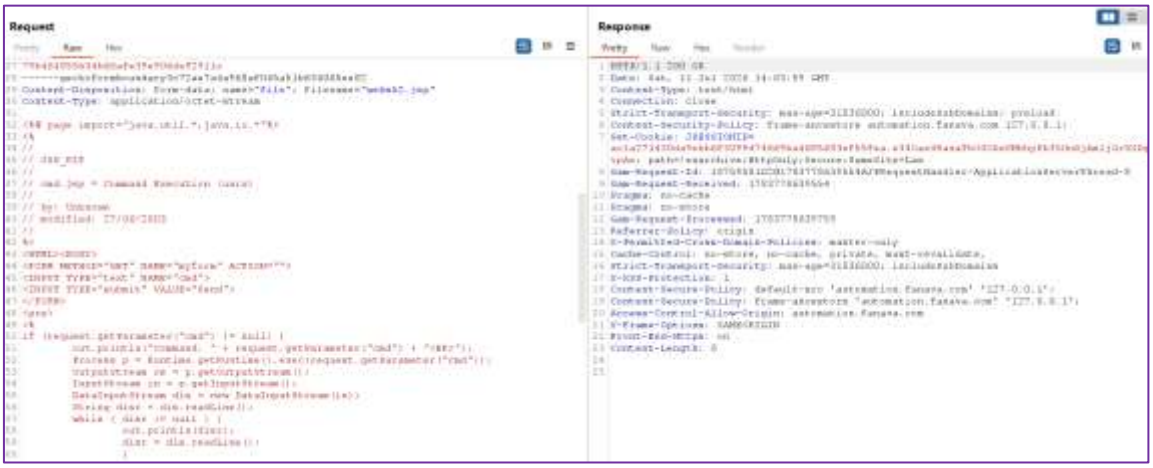


در تصویر زیر کاربر فایل مد نظر خود را انتخاب می‌کند و سپس بر روی گزینه ثبت کلیک می‌کند:

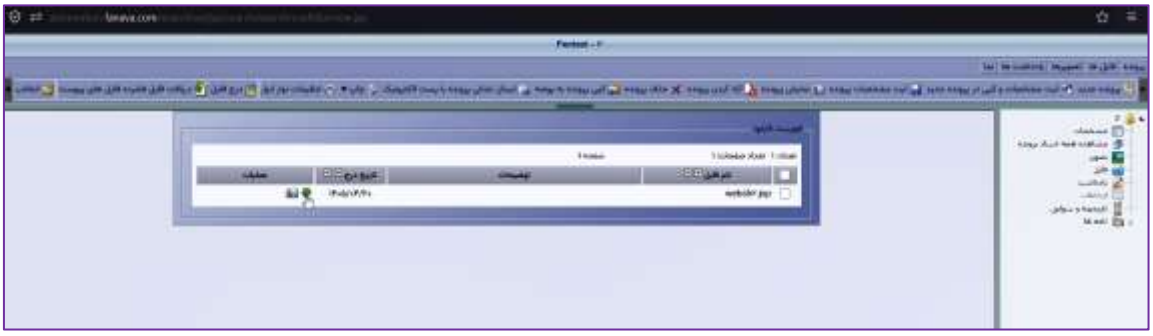


تصاویر زیر درخواست ثبت فایل را نشان می‌دهد. در این درخواست یک نمونه وب شل jsp با پسوند jsp به سمت سامانه ارسال شده است:





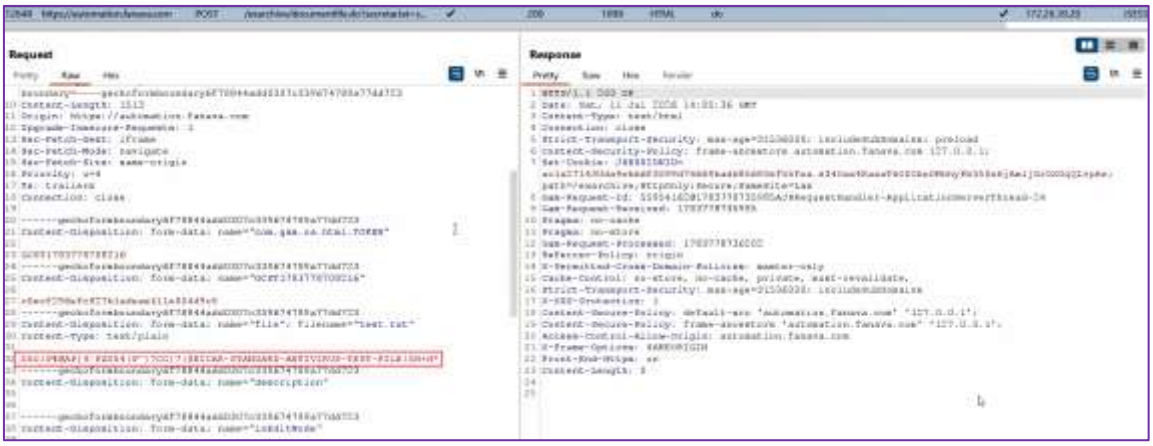
همان‌طور که در تصویر زیر قابل مشاهده است این فایل با موفقیت در سامانه بارگذاری شده است:



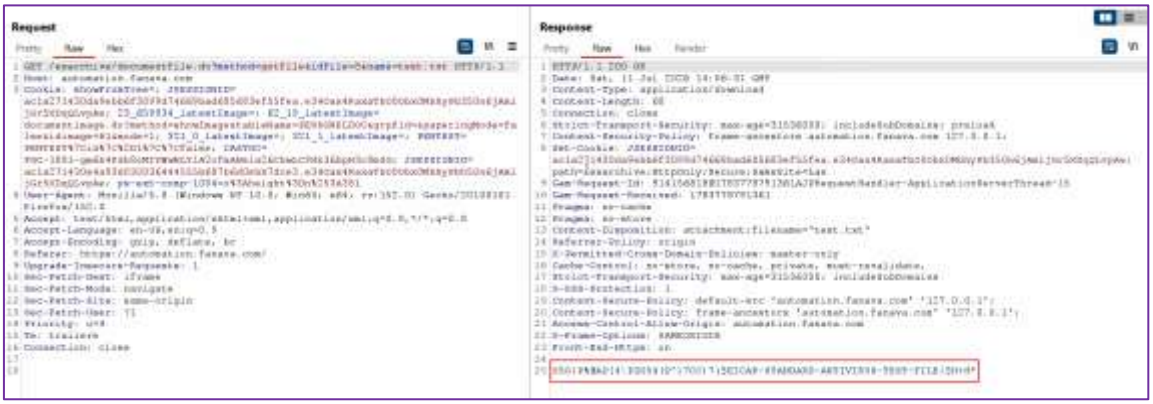
تصویر زیر درخواست مشاهده فایل را نشان می‌دهد. محتوای فایل مخرب در این تصویر قابل مشاهده می‌باشد:



در تصویر زیر یک فایل text با محتوای EICAR به سمت سامانه ارسال شده است. درخواست با موفقیت به سمت سامانه ارسال شده است و پاسخ با کد ۲۰۰ از سمت سامانه بازگشت داده شده است:



تصویر زیر درخواست مشاهده فایل را نشان می‌دهد:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- تشخیص نوع فایل‌ها قبل از بارگذاری فایل
- اسکن فایل جهت جلوگیری از بارگذاری ویروس‌ها
- محتوای فایل مطابق با فرمت فایل ارسالی باشد و از ارسال فایل‌هایی که محتوی آن با فرمت آن‌ها مطابقت ندارد جلوگیری شود.

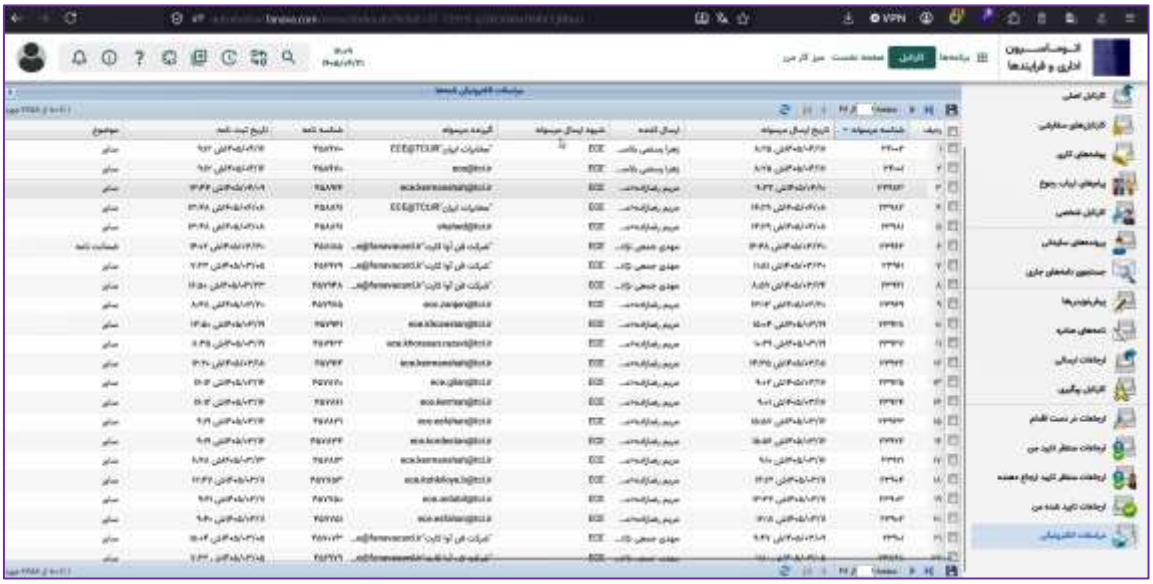
آسیب‌پذیری DoS

سامانه در هر لحظه باید قادر به سرویس‌دهی در حجم محدود و منطقی از درخواست‌ها باشد و از پاسخگویی به درخواست‌های خاص که هزینه پاسخگویی را برای سرور بالا می‌برد خودداری کند، زیرا در غیر این‌صورت سامانه از دسترس خارج خواهد شد.

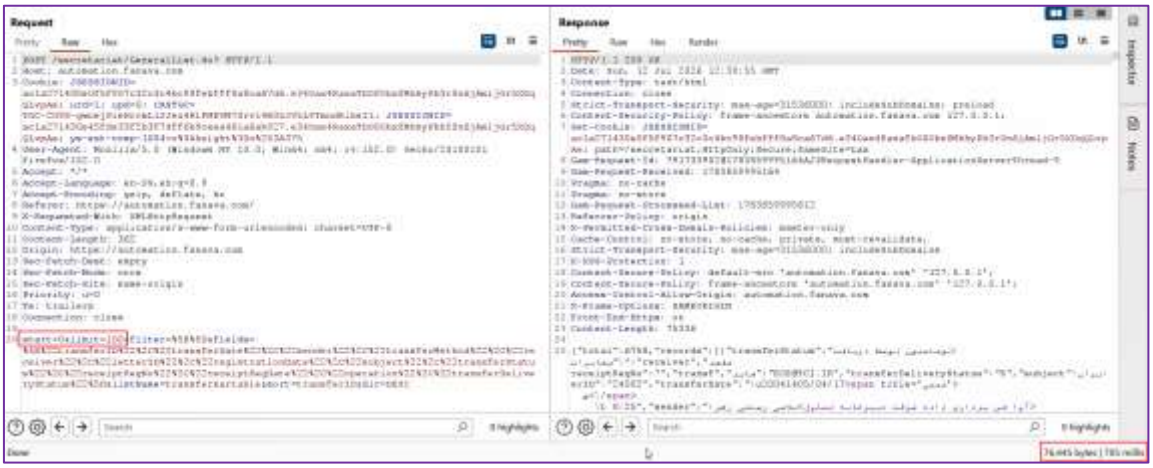
شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش مراسلات الکترونیکی لیستی از داده‌ها در تعداد محدود نمایش داده می‌شود. با افزایش تعداد داده‌های بازگشتی در این بخش حجم Response سرور و همچنین مدت زمان پاسخگویی سامانه افزایش پیدا می‌کند. مهاجم با ارسال این درخواست به صورت متوالی می‌تواند سامانه را برای مدتی از دسترس خارج کند.

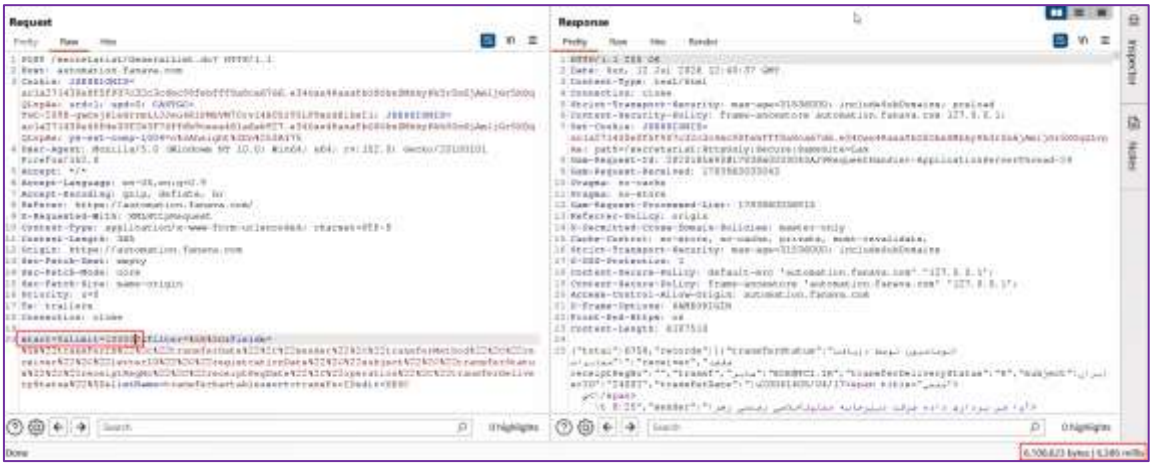
تصویر زیر بخش مراسلات الکترونیکی را نمایش می‌دهد:



درخواست مشاهده داده‌های این بخش به شرح زیر است. همان‌طور که در تصویر زیر قابل مشاهده است مقدار داده‌های بازگشتی در این بخش محدود به ۱۰۰ عدد است. حجم و مدت زمان پاسخگویی سرور نیز در این تصویر نمایش داده شده است:



مهاجم عدد ۱۰۰ را به ۱۰۰۰۰۰ افزایش می‌دهد. همان‌طور که در تصویر زیر قابل مشاهده است مدت زمان پاسخگویی سامانه از ۷۰۵ میلی ثانیه به حدود ۶ ثانیه افزایش یافته و داده‌های بازگشتی از حدود ۷۶ هزار بایت به حدود ۶ مگابایت افزایش یافته است:



مهاجم با ارسال این درخواست به صورت متوالی می‌تواند منجر به از دسترس خارج شدن سامانه بشود.

به دلیل عملیاتی بودن سامانه این حمله تنها با تعداد درخواست محدود انجام شده و تنها مستندات آسیب‌پذیر بودن سامانه نسبت به حمله DOS بیان شده است.

راهکار پیشنهادی

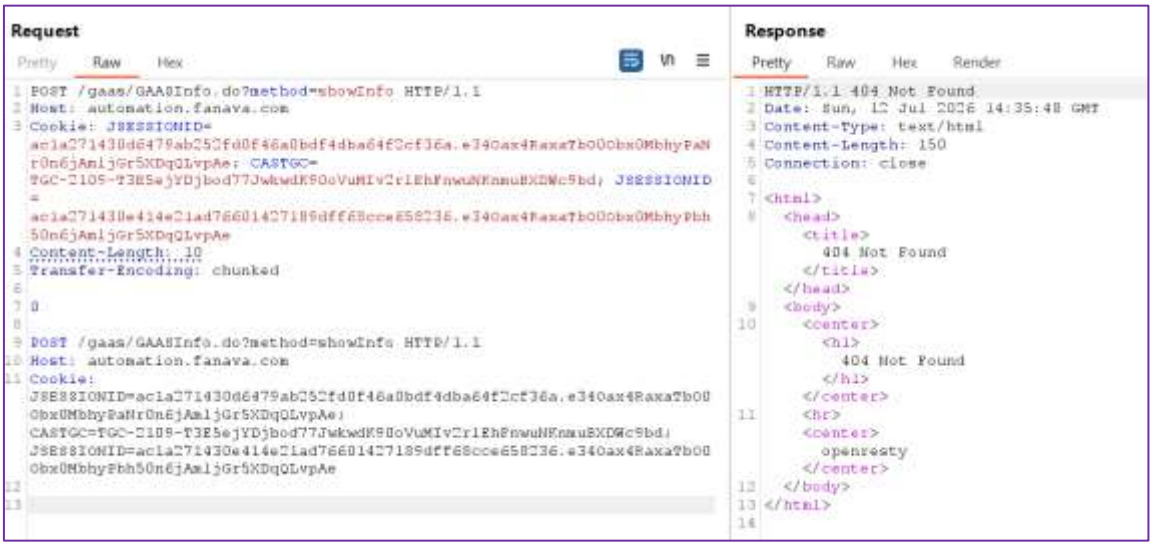
بهتر است اطلاعات صفحات سامانه به صورت محدود به سمت کاربر ارسال شوند و همچنین مکانیزم‌های امنیتی برای جلوگیری از ارسال درخواست‌های متوالی به سمت سامانه مانند WAF پیاده سازی شود.

آسیب‌پذیری عدم مدیریت پیام‌های خطا

معمولا در طی فرایند بررسی نفوذپذیری سامانه، با کدهای خطایی مواجه می‌شویم که می‌تواند اطلاعات بسیار ارزشمندی درباره نوع و نسخه تکنولوژی‌های استفاده شده در سامانه را در اختیار نفوذگر قرار دهد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه با ارسال یک درخواست نامعتبر خطای مربوط به openresty در صفحه نمایش داده می‌شود:



راهکار پیشنهادی

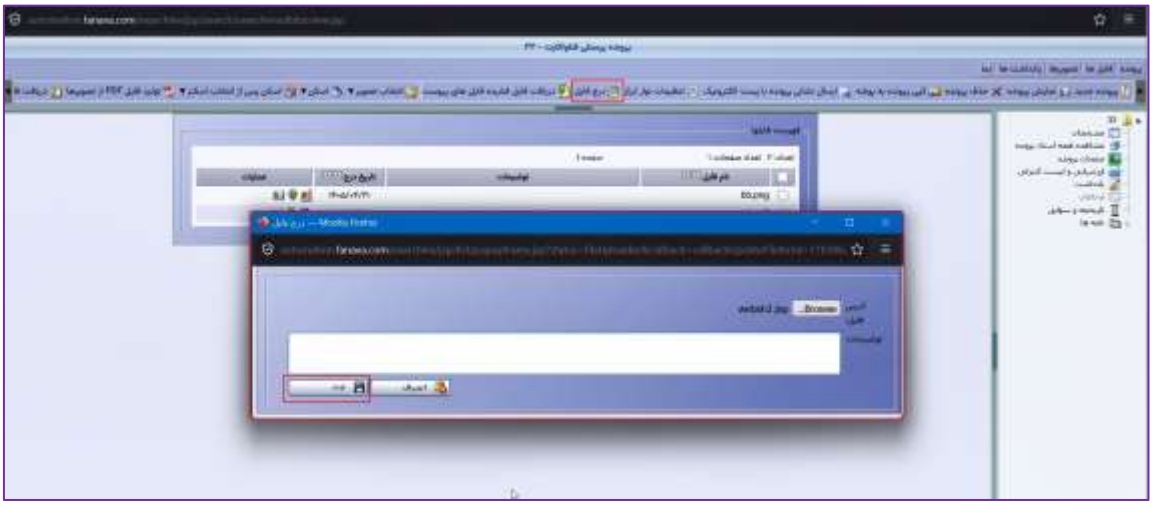
به منظور رفع این آسیب‌پذیری، پیشنهاد می‌شود برای نمایش خطاها از صفحات شخصی سازی شده استفاده شود تا از افشای اطلاعات درباره نوع و نسخه وب سرور سامانه جلوگیری کند.

آسیب‌پذیری بارگذاری فایل با حجم بالا

بارگذاری فایل بدون محدودیت در حجم بارگذاری، ریسک‌های قابل توجهی برای برنامه کاربردی دارد که یکی از آن‌ها اختلال در سرویس دهی سامانه می‌باشد.

شواهد اثبات آسیب پذیری

تصویر زیر بخش بارگذاری فایل در یکی از آرشیوهای سامانه را نشان می‌دهد. با کلیک بر روی گزینه درج فایل امکان انتخاب یک فایل وجود دارد. با کلیک بر روی گزینه ثبت فایل به سمت سرور ارسال می‌شود:

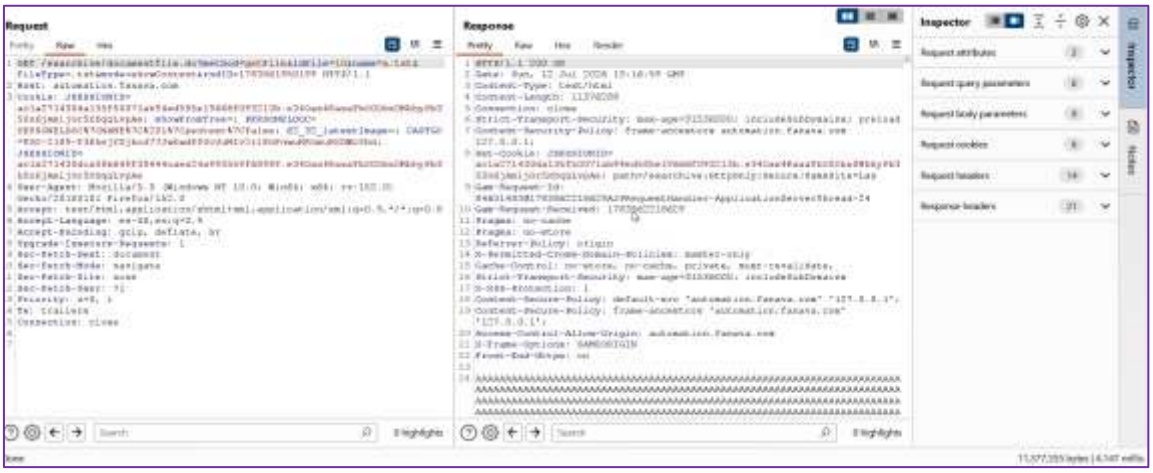


مهاجم در این بخش یک فایل text به حجم ۱۰ مگابایت به سمت سامانه ارسال می‌کند. همان‌طور که در تصاویر زیر قابل مشاهده است با اینکه شاید این فایل سنگین به نظر نرسد اما برای بارگذاری آن یک پردازشی (هر چه قدر کم) از سمت سرور انجام می‌شود:





این فایل به عنوان نمونه به سمت سرور ارسال شده است اما امکان بارگذاری فایل سنگین تر و یا حتی بارگذاری چند فایل به صورت همزمان به سمت سرور وجود دارد که می‌تواند در نهایت منجر به پر شدن فضای ذخیره سازی سرور و از دسترس خارج شدن سامانه شود. خروجی فایل ارسال شده در تصویر زیر قابل مشاهده می‌باشد:



راهکار پیشنهادی

به منظور جلوگیری از بروز این آسیب‌پذیری کنترل حجم بارگذاری فایل جهت جلوگیری از حملات منع خدمت و کنترل حجم مجاز برای هر کاربر انجام شود.

آسیب‌پذیری اعتبارسنجی نامناسب ورودی‌ها

آسیب پذیری اعتبار سنجی ورودی یا input validation، فرایندی است که در آن، ورودی‌های یک برنامه یا سیستم به دقت بررسی می‌شوند تا اطمینان حاصل شود که این ورودی‌ها مطابق با انتظارات و محدودیت‌های تعریف شده هستند و از بروز آسیب پذیری‌های امنیتی مانند sql injection و یا افشای اطلاعات کاربر جلوگیری می‌کنند.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش‌هایی از سامانه که ورودی از کاربر دریافت می‌شود هیچ اعتبار سنجی بر روی درستی ورودی ارسال شده به سمت سامانه وجود ندارد. در این سند بخش آرشیوها و پرونده پرسنلی کارمندان مورد بررسی قرار گرفته است.

تصویر زیر بخش آرشیو و پرونده پرسنلی کاربران نمایش داده شده است:



کاربر بر روی گزینه جدید کلیک می‌کند. در این بخش از کاربر شماره پرسنلی و نام و نام خانوادگی و کد ملی درخواست می‌شود. بخش شماره پرسنلی و کد ملی باید به صورت عددی وارد شوند اما کاربر در این بخش این مقادیر را به صورت یک رشته از حروف وارد می‌کند و بر روی گزینه ذخیره سازی کلیک می‌کند. همان‌طور که در این تصویر قابل مشاهده است فرایند ذخیره سازی با موفقیت انجام شده است:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- **Validations**: بررسی‌هایی که بر روی ورودی‌ها انجام می‌شوند تا اطمینان حاصل شود که ورودی‌ها مطابق با فرمت، طول و نوع داده‌ای تعریف شده هستند.
- **Sanitization**: تصفیه ورودی‌ها از هرگونه کاراکتر یا کد مخرب قبل از اینکه به داخل برنامه یا پایگاه داده وارد شوند.
- **Escaping**: تغییر کاراکترهای خاص در ورودی‌ها به گونه‌ای که آنها به عنوان کد شناسایی نشوند و از حملات تزریق کد جلوگیری شود.
- **Blacklisting**: فیلتر کردن و مسدود کردن ورودی‌های خاص که شناخته شده‌اند و می‌توانند خطرناک باشند.
- **Whitelisting**: مجوز دادن تنها به ورودی‌هایی که در لیست سفید قرار دارند و شناخته شده و امن هستند.

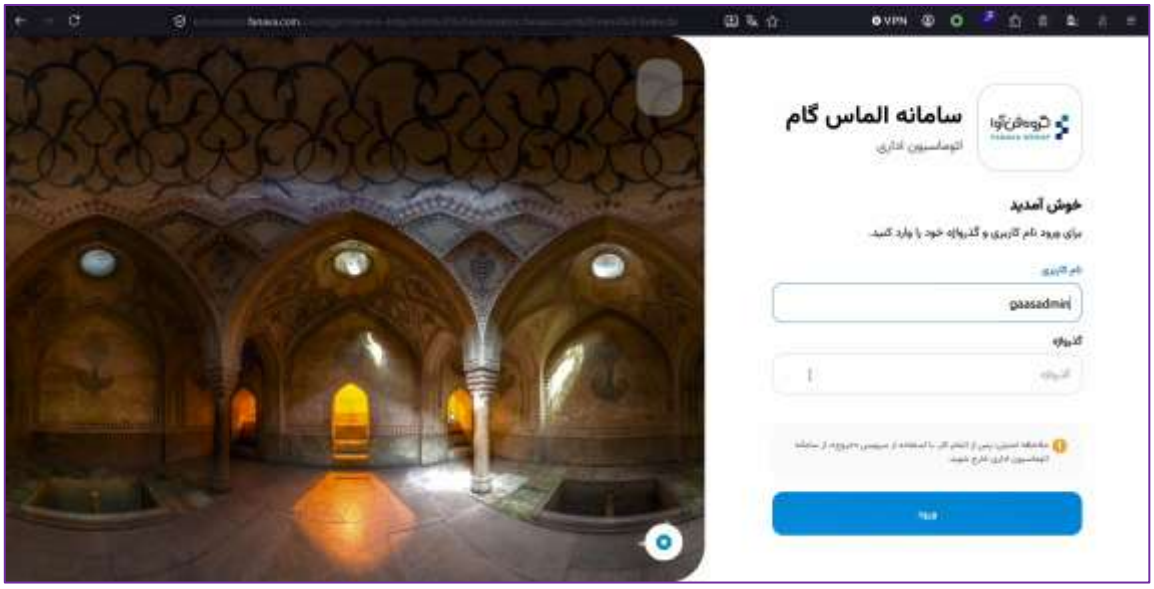
آسیب‌پذیری Client IP Manipulation

آسیب‌پذیری دستکاری آدرس IP کلاینت (Client IP Manipulation) زمانی رخ می‌دهد که یک مهاجم بتواند با دستکاری هدرهای HTTP مانند X-Forwarded-For، آدرس IP خود را طوری جعل کند که سرور آن را آدرس IP واقعی کلاینت تلقی کند. این آسیب‌پذیری می‌تواند منجر به دور زدن تدابیر امنیتی مبتنی بر IP، مانند کنترل‌های دسترسی و محدودیت‌های نرخ، شود و دسترسی‌های غیرمجاز را فراهم کند.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده در سامانه، با قرار دادن سرایند X-Forwarded-For در درخواست‌های ارسالی به سمت سامانه، امکان دستکاری آدرس IP وجود دارد.

تصویر زیر صفحه ورود به سامانه را نشان می‌دهد:



مهاجم با وارد کردن اطلاعات ورود و قرار دادن سرایند X-Forwarded-For درخواست ورود را به سمت سامانه ارسال می‌کند:



در تصویر زیر کاربر به صفحه تاریخچه ورود خود مراجعه می‌کند. همان‌طور که در این درخواست قابل مشاهده است آدرس سیستم با موفقیت تغییر یافته است:



راهکار پیشنهادی

استفاده از ماژول‌هایی مانند mod_remoteip در آپاچی، اطمینان از پیکربندی صحیح و قابل اعتماد بودن هدرهای پروکسی، و استفاده از پروتکل‌های امن‌تر مانند Proxy Protocol در لایه TCP است.

آسیب‌پذیری Weak Password Policy

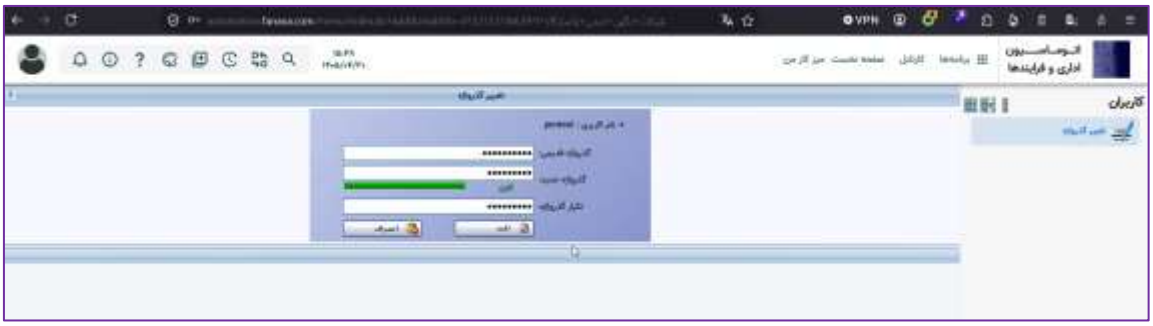
یکی از تکنیک‌های نفوذ به سیستم، شکستن کلمات‌عبور یا Password Cracking می‌باشد. شکستن کلمات‌عبور شامل روش‌هایی مانند حمله حدس کلمات‌عبور، حمله Dictionary که بوسیله تست لیستی از کلمات‌عبور صورت می‌گیرد و حمله Brute Force که شامل تست تمامی حالت‌های موجود می‌باشد، انجام می‌گیرد.

در صورتیکه سیاست‌های لازم جهت انتخاب کلمه‌عبور برای کاربران تعریف نشده باشد، امکان استفاده از روش‌های مذکور توسط نفوذگر متصور می‌باشد که می‌تواند منجر به موفقیت‌آمیز بودن چنین حملاتی شود. به همین دلیل یکی از مواردی که باید در سامانه مورد ارزیابی قرار گیرد، تست سیاست‌های ضعیف کلمات‌عبور است.

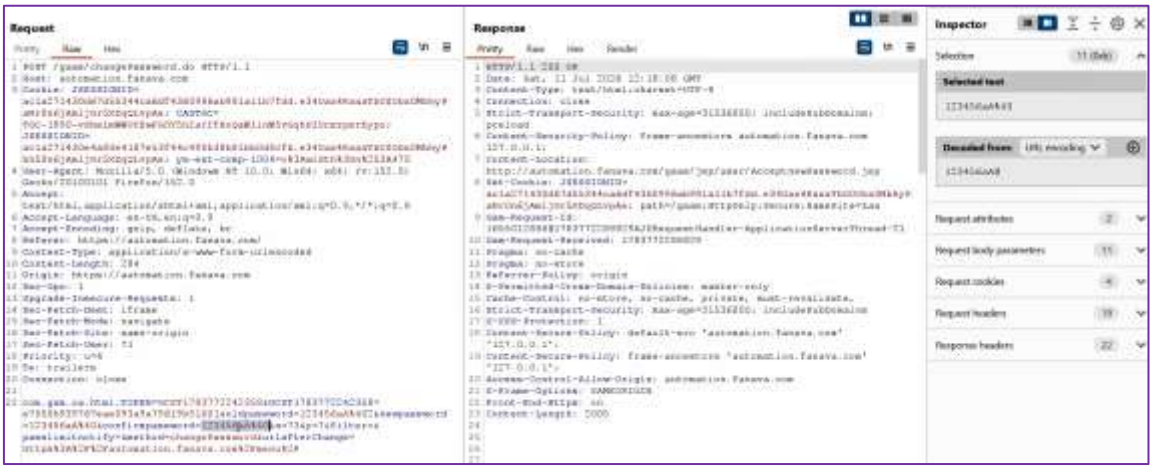
شواهد اثبات آسیب پذیری

با توجه به ارزیابی‌های انجام شده، کلمات عبور استفاده شده در سامانه، ضعیف بوده و قابل حدس هستند.

در تصویر زیر صفحه تغییر رمز عبور قابل مشاهده می‌باشد:



همان‌طور که در درخواست ارسالی به سمت سامانه قابل مشاهده می‌باشد رمز عبور 123456aA@ از کاربر پذیرفته شده است. اگرچه این کلمه عبور از اعداد و حروف و علائم پشتیبانی می‌کند اما بسیار ساده و قابل حدس می‌باشد:



راهکار پیشنهادی

رعایت موارد زیر در تنظیم و تعریف انتخاب کلمه عبور الزامی می‌باشد:

- طول کلمه عبور حداقل ۱۲ کاراکتر باشد.
- کلمه عبور باید ۳ تا از ۴ موارد مرتبط با پیچیدگی کلمات‌عبور را رعایت کند:
  - حداقل یک حرف بزرگ (A-Z)
  - حداقل یک حرف کوچک (a-z)
  - حداقل یک رقم (0-9)
  - حداقل یک کاراکتر خاص (#،!،@،$ و....)

بیشتر از ۲ تا کاراکتر مشابه هم استفاده نشود.

عدم وجود سرآیندهای امنیتی HTTP

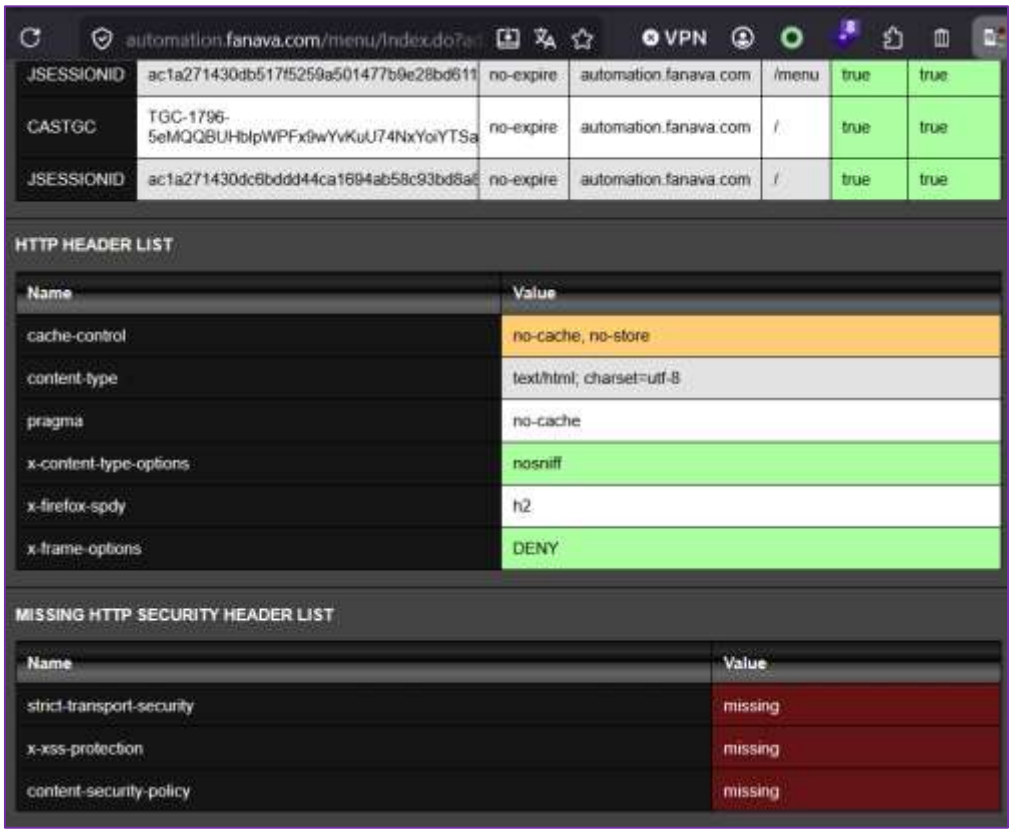
سرآیندهای امنیتی، مجموعه سرآیندی‌هایی هستند که در پاسخ وب‌سرور به سمت مرورگر کاربر ارسال می‌گردند که اغلب باعث افزایش امنیت کاربر در تعامل با سامانه می‌شوند و در صورت غیرفعال بودن هر یک از سرآیندها امکان به وقوع پیوستن حملاتی چون Clickjacking، XSS و... را به همراه دارد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سرایندهای ارسالی در درخواست‌های سامانه، سرایندهای زیر در سامانه وجود ندارند:

Strict-Transport-Security, x-xss protection, Content-Security-Policy

تصویر زیر بررسی سرایندهای سامانه را نشان می‌دهد:



راهکار پیشنهادی

در فایل پیکربندی سامانه سرآیندهای ذکر شده را تنظیم کنید.